



Caso SolarWinds

AUDITORÍA DE SISTEMAS

Wilson Álvarez
Diego Moya
Matías Troncoso
Diego Adrovez

CONTENIDO

- 01 RESUMEN DE LA EMPRESA
- 02 DESCRIPCIÓN DEL ATAQUE
- 03 ANÁLISIS DE AUDITORIA
- 04 SOLUCIÓN
- 05 CONCLUSIÓN

SOBRE SOLARWINDS

SolarWinds es una empresa fundada en 1999 cuyo foco es desarrollar software que ayude a administrar sistemas, redes y otros recursos informáticos.

La columna vertebral de su oferta de productos es la plataforma Orion. Esta plataforma es un conjunto de productos de monitoreo y gestión de TI que incluyen:

- Network Performance Monitor (NPM)
- Server & Application Monitor (SAM)
- Database Performance Analyzer (DPA)



SOLARWINDS®

EL ATAQUE

En 2020, la cadena de suministro fue atacada por hackers desde la "backdoor", la cual fue posteriormente llamada SUNBURST.

Este hackeo les permitió instalar malware a los usuarios de SolarWind, por el cual los atacantes podían ejecutar código remoto y robar datos. Abarcando desde pequeñas y medianas empresas hasta grandes corporaciones y agencias gubernamentales. Entre los afectados por el incidente se encontraron:

- Agencias del gobierno de EE. UU. (Departamento del Tesoro, Departamento de Comercio, Departamento de Energía, entre otros).
- Grandes empresas tecnológicas y de ciberseguridad.
- Universidades e instituciones de investigación.



LINEA DE TIEMPO DEL ATAQUE

**SEPTIEMBRE-
OCTUBRE 2019**

Los atacantes
obtienen
acceso a la
red de
SolarWinds

**FEBRERO - MARZO
2020**

Los atacantes
inyectan
"SUNBURRST" a
las redes, la cual
se propaga a sus
miles de usuarios

**MARZO - DICIEMBRE
2020**

Los atacantes
utilizan el
backdoor para
robar información
a los usuarios
seleccionados

DICIEMBRE 2020

La empresa
FireEye descubre
el ataque y alerta
a SolarWinds y
otros afectados

ANALISIS DE AUDITORIA

Comenzaremos con el marco COSO, el cual establece cinco componentes interrelacionados para efectivo control interno. En el caso SolarWinds, se identificaron fallas en casi todos ellos:

Ambiente de Control: Parecía haber una subestimación del riesgo de ataques a la cadena de suministro o una falta de priorización de la seguridad en el ciclo de desarrollo por parte de la alta gerencia

Evaluación de Riesgos: La falla principal residió en la insuficiente evaluación de riesgos

Actividades de Control: Se detectaron debilidades críticas en las actividades de control preventivas y de detección.

Monitoreo y Comunicación Interna: El hecho de que el ataque persistiera durante meses sin ser detectado internamente apunta a problemas significativos en las actividades de monitoreo.



EVALUACIÓN DESDE COBIT

01

EDM: La supervisión estratégica fue deficiente. Las decisiones sobre inversión y priorización de la seguridad no fueron suficientes para mitigar un riesgo tan crítico.

02

APO: La estrategia de TI de SolarWinds no estuvo suficientemente alineada con la protección contra ataques avanzados a la cadena de suministro.

03

BAI: Los procesos para "Construir, Adquirir e Implementar" soluciones de TI fueron críticamente comprometidos.

04

DSS: La entrega de actualizaciones de software, un proceso crítico, se convirtió en el vector de ataque.

05

MEA: Los procesos de monitoreo y evaluación de la conformidad de TI y los objetivos de desempeño interno fueron ineficaces para detectar la intrusión

SEGURIDAD DE LA INFORMACIÓN

El ataque a SolarWinds puso de manifiesto fallas fundamentales en varios pilares de la seguridad de la información:

Vulnerabilidades Explotadas: La principal vulnerabilidad fue la confianza implícita en la cadena de suministro de software. Los atacantes explotaron la confianza de los clientes en las actualizaciones legítimas de SolarWinds.

Falta de Segmentación, Privilegios Excesivos, Control de Acceso: Una vez dentro de la red de SolarWinds, los atacantes lograron moverse lateralmente con facilidad, indicando una falta de segmentación de red adecuada. Esto también sugiere que los atacantes pudieron escalar privilegios debido a configuraciones laxas o cuentas con privilegios excesivos.

Ausencia o Ineficiencia de SIEM y SOC: El largo período de "tiempo de permanencia" del atacante en las redes afectadas es una clara evidencia de la ineficiencia de los sistemas SIEM y los SOC. No se lograron correlacionar eventos de seguridad que indicaran la intrusión, o las alertas generadas fueron ignoradas o no priorizadas.

APLICACION DEL MODELO ZERO TRUST

El incidente de SolarWinds es un caso de estudio perfecto para argumentar la necesidad de un enfoque Zero Trust.

- Ausencia de Verificación Continua: SolarWinds y sus clientes operaban bajo un modelo de confianza implícita: se confiaba en que una vez que el software era de una fuente "legítima" (SolarWinds), era seguro. Esto violó el principio de "Comprobación Explícita" de Zero Trust, que requiere verificar y autenticar cada solicitud de acceso, sin importar la ubicación o el origen.
- Falta de Privilegios Mínimos: La capacidad de los atacantes para escalar privilegios y moverse lateralmente indica que no se aplicaron los principios de "privilegios mínimos" o "Just-in-Time/Just Enough Administration (JIT/JEA)". Si los sistemas comprometidos hubieran tenido un acceso mínimo a otros recursos, el alcance del ataque se habría limitado.
- Recomendación de Transición: El ataque a SolarWinds es una clara demostración de que el modelo de "confianza implícita" ya no es sostenible. Una transición hacia una arquitectura Zero Trust habría mitigado significativamente el impacto.

SOLUCIONES Y RECOMENDACIONES

Las soluciones propuestas se basan en la aplicación de los marcos de control y buenas prácticas para abordar las deficiencias identificadas en el caso SolarWinds.

1. Refuerzo del Control Interno (COSO)

- **SSDLC Integrado:** Implementar un Ciclo de Vida de Desarrollo de Software Seguro (SSDLC) mandatorio, integrando la seguridad en cada fase del desarrollo
- **Hardening y Configuración Segura:** Aplicar rigurosamente los CIS Benchmarks para la configuración segura de todos los sistemas operativos, bases de datos y aplicaciones utilizadas en el desarrollo y producción.

2. Monitoreo Continuo y Comunicación

- **Visibilidad 360:** Aumentar la visibilidad sobre los sistemas de desarrollo y producción, recopilando y centralizando logs de todas las fuentes relevantes.

SOLUCIONES Y RECOMENDACIONES

3. Plan de Mejora Basado en COBIT 2019

EDM: Establecer un Comité de Gobierno de Seguridad de la Información a nivel de junta directiva.

APO: Desarrollar una estrategia de seguridad de TI específica para la cadena de suministro de software.

BAI: Implementar un programa robusto de gestión de riesgos de proveedores e integrar herramientas de seguridad automatizadas para escanear y probar el código en cada etapa

DSS: Desarrolla un plan de respuesta a incidentes y fortalecer los controles de gestión de cambios para prevenir la introducción de código malicioso.

MEA: Realizar auditorías internas y externas frecuentes para evaluar la madurez de los procesos de seguridad.

SOLUCIONES Y RECOMENDACIONES

4. Seguridad Cloud y DevSecOps

- **Integración de DevSecOps:** Adoptar plenamente un modelo DevSecOps . Esto significa "shift-left security", incorporando la seguridad desde el diseño y la planificación, hasta la codificación, pruebas, despliegue y monitoreo.
- **Aplicación de CIS Benchmarks:** Implementar y mantener de forma proactiva configuraciones de seguridad endurecidas en todos los sistemas, siguiendo las guías de **CIS Benchmarks** para reducir la superficie de ataque.

SOLUCIONES Y RECOMENDACIONES

5. Implementación Efectiva de SIEM y SOC

- **SIEM Avanzado:** Desplegar una solución SIEM (Security Information and Event Management) robusta capaz de ingerir y correlacionar grandes volúmenes de logs de diversas fuentes
- **SOC Operativo:** Establecer o fortalecer un Centro de Operaciones de Seguridad (SOC)
- **Inteligencia de Amenazas:** Integrar fuentes de inteligencia de amenazas para comprender las TTPs (Tácticas, Técnicas y Procedimientos) de APTs y mejorar las capacidades de detección proactiva.

SOLUCIONES Y RECOMENDACIONES

6. Implementación de arquitectura Zero Trust

- **Comprobación explícita:** Implementar una política de "confianza cero" en toda la organización.
- **Acceso Mínimo:** Aplicar el principio de "privilegios mínimos" y "Just-in-Time/Just Enough Administration (JIT/JEA)" para todos los usuarios y sistemas, especialmente para aquellos con acceso a entornos de desarrollo y producción críticos.
- **Segmentación de Confianza:** Implementar micro-segmentación de red y aplicaciones para crear perímetros de seguridad granulares

CONCLUSIÓN

La auditoría de sistemas y seguridad informática demostró ser una herramienta de valor incalculable para desentrañar las capas de este complejo ataque. Permitted identificar que las fallas no se limitaron a un único punto de control, sino que fueron sistémicas, afectando el ambiente de control, la evaluación de riesgos, las actividades de control (especialmente en el desarrollo), el monitoreo continuo , y la gobernanza y gestión de TI. La ausencia de una arquitectura Zero Trust y un enfoque DevSecOps eficiente fueron factores críticos que permitieron la infiltración y proliferación del ataque.